

Digital souverän am Beispiel von eduMFA

Peter Gietz, DAASI International

Tübix 2026,
Tübingen 4.7.2026

Agenda

- Kurze Vorstellung
- Kurze Begriffsklärung IAM Föderationen und MFA
- Open Source und Digitale Souveränität
- Freedom of Forking: die Genese von eduMFA
- eduMFA was es ist, was es kann, wer es unterstützt, wie man es mit anderen Systemen integrieren kann
 - Folien zu Enrollement-Strategien werde ich größtenteils überspringen, um im Zeitfenster zu bleiben
 - Zahlen in eckigen Klammern, beziehen sich auf Fußnoten auf der letzten Folie

Über DAASI International

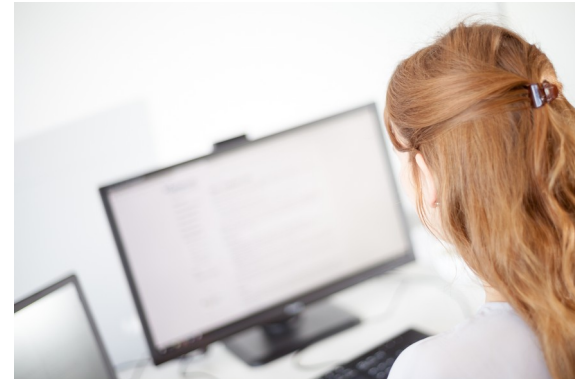
Gründung

- 2000 in Tübingen mit 4 Mitarbeiter*innen
- als Spin-Off des ZDV der Universität Tübingen
- aus DFN-Projekten zu X.500/LDAP

Stand 2026

- 28 Mitarbeiter*innen
- ~ 20 FTE
- > 2 Millionen Jahresumsatz

Die DAASI International ist ein erfolgreicher PoC für ein nicht skalierendes aber nachhaltiges Businessmodell auf Open-Source-Grundlage



DAASI International steht für digitale Souveränität

- Open Source für Flexibilität und digitale Souveränität
- Datenschutz für informationelle Selbstbestimmung und digitale Souveränität
- Offene Standards für Interoperabilität und Kombinationsmöglichkeiten, was ebenfalls digitale Souveränität fördert

Identity & Access Management (IAM) und Multi-Faktor-Authentifizierung (MFA) kurze Begriffsklärung

IdM- / IAM-Definition

Definition Identity Management von Spencer C. Lee

Identity Management bezieht sich auf den *Prozess* der Implementierung *dedizierter* Technologien zum Verwalten von Informationen über die Identität von Nutzer*innen und zur Kontrolle des Zugriffs auf Firmenressourcen.

Ziel

Das Ziel von Identity Management ist es, Produktivität und Sicherheit zu erhöhen und gleichzeitig die Kosten der Verwaltung von Benutzer*innen, ihrer Identitäten, Attribute und Berechtigungsnachweise zu senken (Erleichterung für Nutzer*innen und Administrator*innen).

IdM/IAM Definition

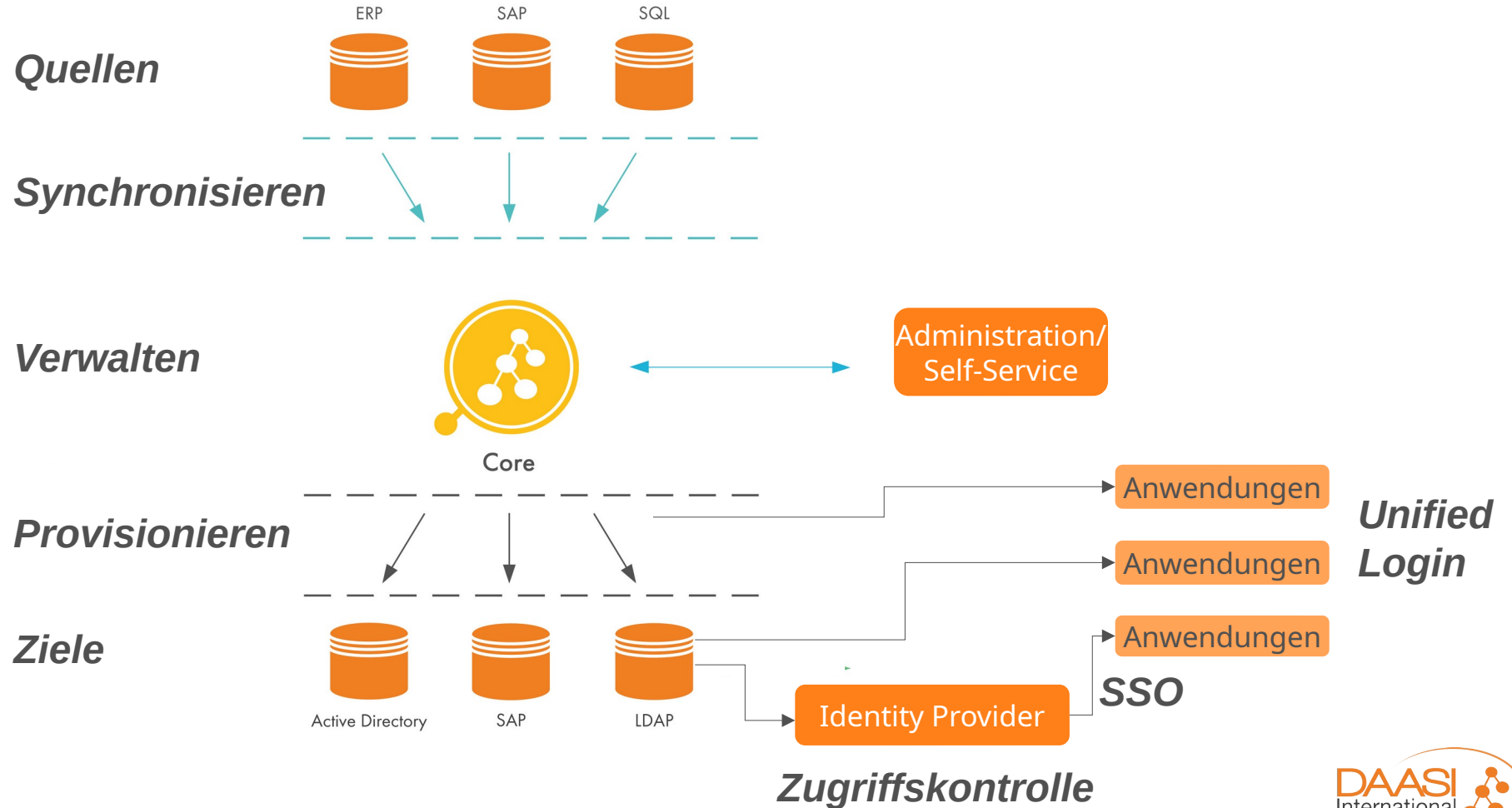
Definition Access Management

Inzwischen spricht man bevorzugt von IAM, wobei das A für Access steht.

Der Begriff **Access Management** umfasst IT-Systeme, die Zugang zu Ressourcen unterschiedlicher Art verwalten. Access Management ist somit eine IT-gestützte Zugriffskontrolle auf beispielsweise Computer, Speicher, Dateien, Datensätze, Softwaredienste oder Anwendungen.

*Föderationen, in denen einem Dienst durch den Heimat Identity Provider Attributen der User*in geschickt werden, auf deren Grundlage der Dienst Autorisierungsentscheidungen treffen kann, sind Teil des Access Managements (s.u.)*

IAM unser Verständnis



Definition Föderiertes Identity Management

Peter Valkenburg, et alii (SURF) definiert:

„Kollektiver Begriff für alle Prozesse, Standards und Technologien, die den Austausch von Identitätsinformationen über organisatorische Grenzen hinweg unterstützen.“

Voraussetzungen

Identity Management ist Voraussetzung für Federated Identity Management, da Zusagen über Aktualität und Richtigkeit der Identitätsdaten gemacht werden.

FIdM setzt eine Föderation voraus

- Ein Vertrauensbund, der es ermöglicht, verteilte Ressourcen gemeinsam zu nutzen.
- Vertrauen wird durch Verträge und Einhaltung von entsprechenden Sicherheitspolicys gewährleistet.

Grundbausteine einer Föderation

Föderationsverwaltung

- zentraler Vertragspartner für Föderationsmitglieder
- verwaltet Zugangsdaten zu den einzelnen Bausteinen (“Metadaten”)
- betreibt zentrale Infrastrukturkomponenten

Identity Provider (IdP)

- Benutzerverwaltung der Heimatorganisation
- verantwortlich für Authentifizierung und Attribut

Service Provider (SP)

- verantwortlich für Ressourcen
- entscheidet aufgrund von Aussagen des IdP

FIM und Datenschutz

Identitätsdaten von Benutzer*innen müssen nur noch an einer Stelle gespeichert werden

- Name, Kontaktdaten, Passwort etc.
- im IdP der „Heimatorganisation“

Personenbezogene Daten

- werden nur über gesicherte Verbindungen an Mitglieder des Vertrauensbundes geschickt
- müssen aber gar nicht übertragen werden, da es nur auf Autorisierungsattribute ankommt

Integration von Anwendungen in ein IAM

SPML Service Provisioning Markup Language

SCIM Simple Cross-organizational Identity Management

ADSI Active Directory Service Interface

LDAP Lightweight Directory Access Protocol

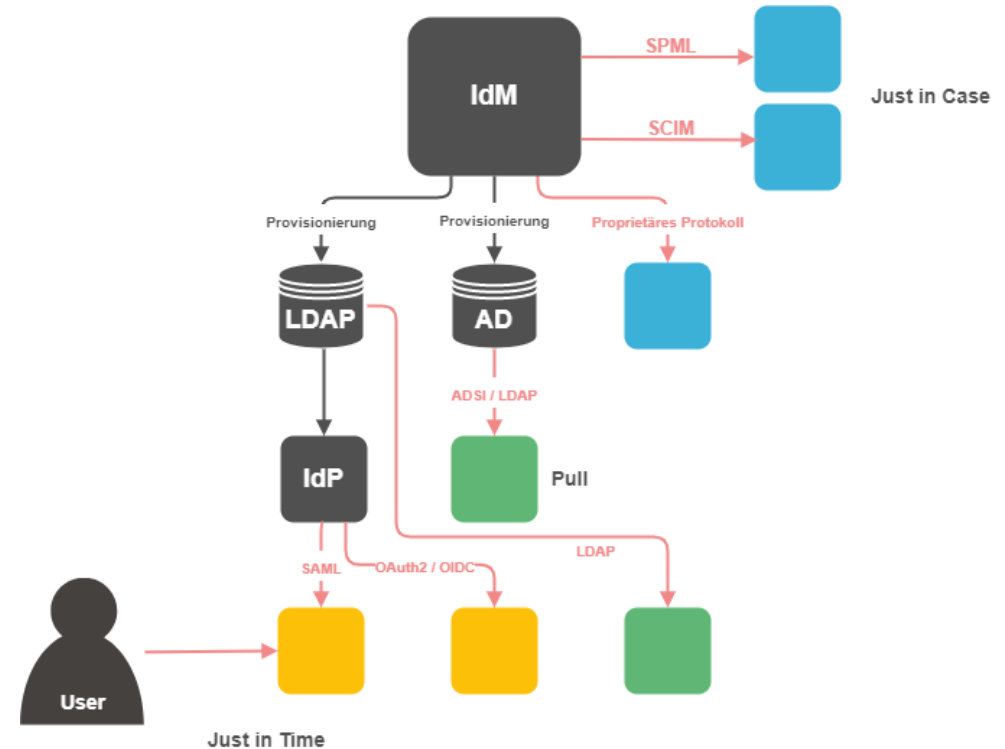
SAML Security Assertion Markup Language

OAuth2 Open Authorization

OIDC Open ID Connect

IdM Identity Management

IdP Identity Provider



MFA: Motivation

- Wenn Accounts gehackt worden sind, kann erheblicher Schaden angerichtet werden:
 - Spam-Schleuder
 - Ausspähen von Daten
 - Weitere Accounts kompromittieren
 - Verschlüsselungserpressung
 - ...
- Multi-Faktor-Authentifizierung (MFA) ist ein wirksames Mittel zur Erhöhung der Sicherheit bei Authentifizierungsprozessen, die in der Regel als ersten Faktor das Passwort beinhalten.
- Username/Passwort gilt alleine nicht mehr als sicher genug:
 - In manchen Systemen nicht erzwingbare Passwortstärken
 - Schwache Passwörter können einfach „geknackt“ werden
 - Passwörter können willentlich oder nicht-willentlich an Andere weitergegeben werden
 - Social engineering
 - Phishing

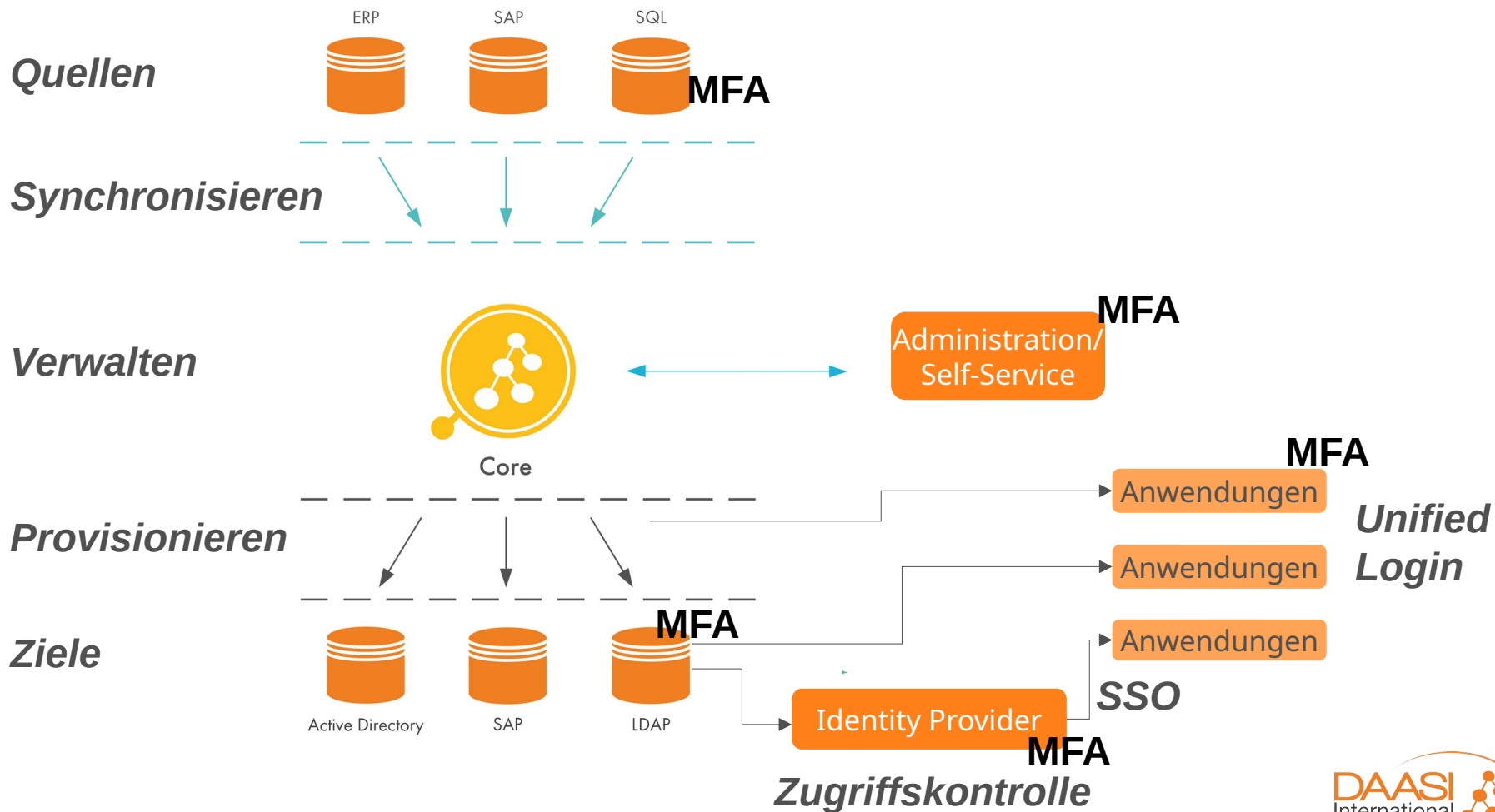
MFA: Motivation

- Gemäß DSGVO werden beim Single Sign-On (und anderen Authentifizierungsdiensten etc.) personenbezogene Daten verarbeitet.
- Nach Art. 25 Abs. 1 DSGVO und Art. 32 DSGVO müssen die Dienste nach dem "Stand der Technik" betreiben.
- Eine entsprechende Richtlinie des BSI (TR-03107-1 [9]) besagt Folgendes (nach Steffen Hofmann):
 - Ein Single Sign-On System ist als Gesamtsystem zu betrachten. Es wird sogar explizit der Begriff "Identity Provider" verwendet.
 - Das Vertrauens-/Sicherheitsniveau der angeschlossenen Dienste ist in der Gesamtheit mindestens als substantiell zu betrachten.
 - Selbst wenn die Service Provider einzeln betrachtet werden, gilt für keine Beschäftigten einer Hochschule, dass sie nur Dienste mit dem Niveau "normal" benutzen.
 - Gemäß 4.4 "Nutzername/Passwort": "Es kann nur das Vertrauensniveau normal erreicht werden." Das wird auch in 10.4.3 noch einmal unterstrichen: "Mit diesem Mechanismus kann nur das Vertrauensniveau normal erreicht werden."
 - Es werden für "substantiell" mindestens noch TAN-Verfahren benötigt (5.3 Mechanismen)
 - Nach Abschnitt 9 übermitteln wir Identitätsdaten und 9.1 "Funktionen". Schon allein damit muss die Richtlinie angewandt werden.
- Daraus folgt: **Man kann hieraus den gesetzlichen Zwang, MFA einzuführen ableiten.**

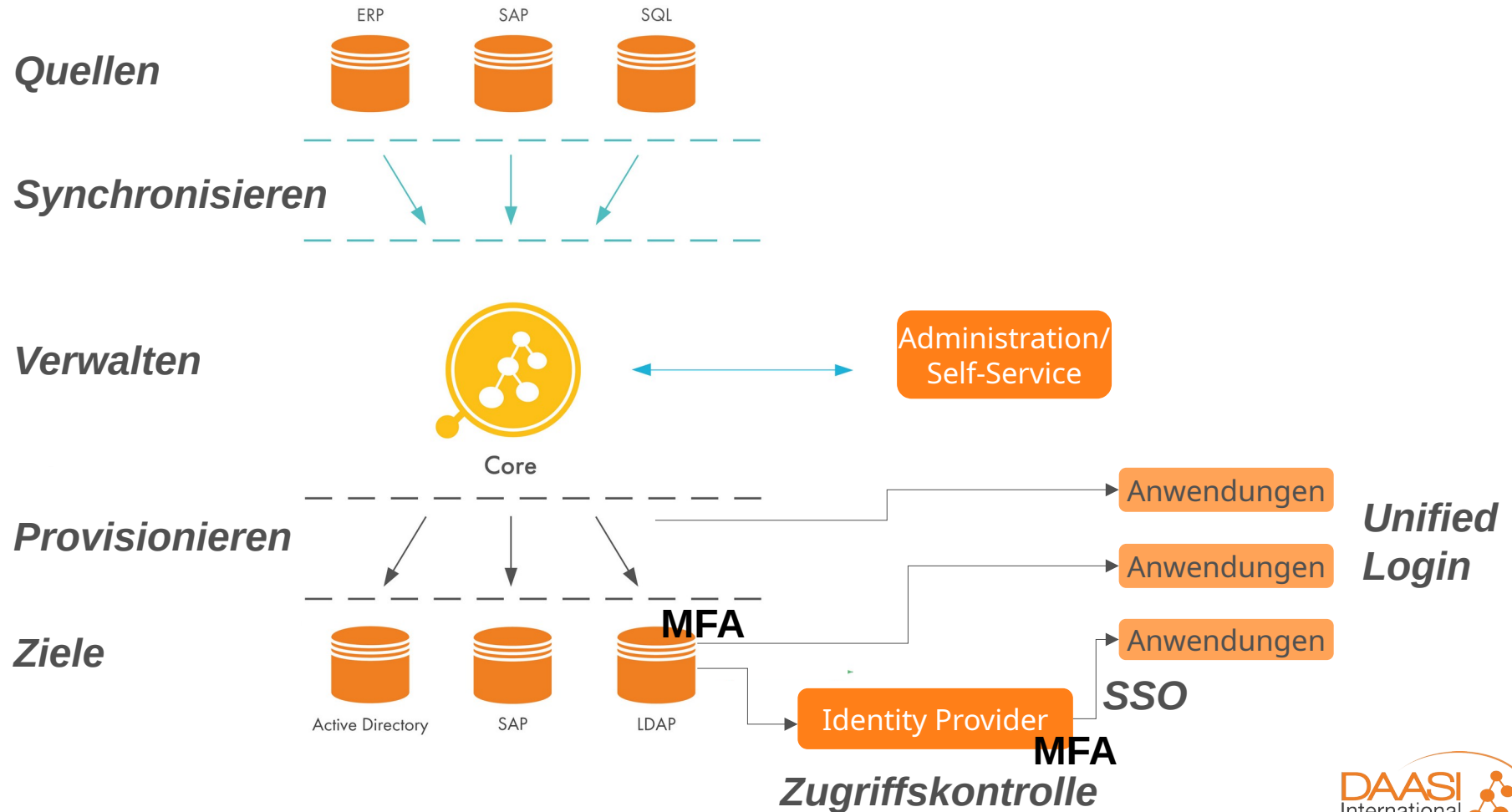
Multi Factor Authentication (MFA)

- Nach ITU-T X.1254 (Entity authentication assurance framework) lassen sich vier Faktoren zur Authentifizierung unterscheiden:
 - Wissen (z. B. Passwort, PIN)
 - Haben (z. B. Hardware-Token, privater Schlüssel)
 - Sein (biometrische Merkmale)
 - Tun (Verhaltensmuster)
- MFA findet dann statt, wenn eine Kombination dieser Faktoren für die Authentifizierung verwendet wurde
- Die verwendeten Faktoren müssen dabei unabhängig voneinander sein. Sprich: Zugriff auf einen Faktor ermöglicht keinen Zugriff auf einen anderen Faktor
- 2FA kann synonym verwendet werden, jedoch schließt MFA auch Prozesse mit mehr als 2 Faktoren mit ein

MFA lässt sich an vielen Stellen implementieren



MFA sollte aber so zentral wie möglich implementiert werden



Open Source (OS) und digitale Souveränität

Am Anfang war Open Source

Hochschulen betrieben Großrechner [1]

- z. B. Zuse Z22, 1957 mit Trommelspeicher und Lochkartenlocher
- Hardware wurde mit Betriebssystem und Compiler geliefert (ohne Zusatzkosten)

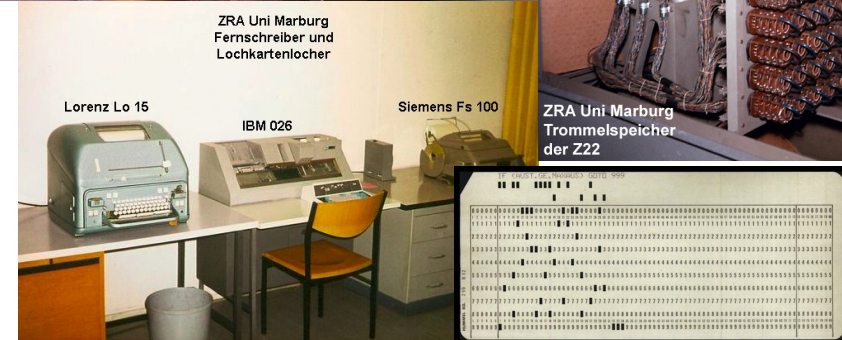
Software wurde ausschließlich von den Nutzer*innen geschrieben und im Code geteilt

- „distributed under the principles of openness and cooperation long established in the fields of academia“ [2]
- „Such communal behavior later became a central element of the so-called hacking culture“ [2]

SHARE ist erste (1955) User Group für IBM Mainframes

- „Its not an acronym, it's what we do“ [3]

*„46 Benutzer*innen aus 16 Instituten nutzen die Z22 in 1964 für ca. 65 Aufgabenstellungen. Die Nutzung erfolgt zu mehr als 90 % durch Programme im Freiburger Code (eine Art Assembler), der Rest ist in Algol.“ [1]*



Punctum.com

Open-Source-Definition von OSI

Open Source Initiative

- sieht sich primär als Verwalter ihrer OS-Definition als Grundlage des OSS-Ökosystems
- listet mit der Definition kompatible OS-Lizenzen

Die OS-Definition hat 10 Merkmale [5]:



1. Software wird **frei zur Verfügung** gestellt (*free redistribution*)
2. **Source Code** wird mit verteilt (*must include source code*)
3. Lizenz muss **Modifikationen des Codes** erlauben (*derived works*)
4. Solche Änderungen müssen zu einem neuen Namen oder einer neuen Versionsnummer der Software führen, um **Autorenschaft zu dokumentieren** (*Integrity of The Author's Source Code*)
5. Nutzung **darf nicht auf bestimmte Gruppen eingeschränkt werden** (*no discrimination against persons or groups*)
6. Nutzung **darf nicht auf bestimmte Domänen eingeschränkt werden** (*no discrimination against fields of endeavor*)
7. **Gleiche Lizenz für alle** (*Distribution of License*)
8. **Produktunabhängig**: Rechte dürfen nicht von einer Distribution etc. abhängig sein (*license must not be specific to a product*)
9. **Softwareunabhängig**: man darf nicht verlangen, dass die SW nur zusammen mit anderer SW verbreitet wird (*license must not restrict other software*)
10. **Technologieneutrale** Verteilung über beliebige Medien (*license must be technology-neutral*)

Vorteile von Open Source

- kein Vendor-Lock-in
 - Kunde hat stärkere Position gegenüber den Herstellern und kann die Roadmap wesentlich besser beeinflussen
 - Wer den Code besitzt, hat die Macht
- **maximale Flexibilität und Unabhängigkeit**
 - **erweiterbar und anpassbar bei neuen Anforderungen durch Hersteller, den Kunden selbst, oder einem dritten Dienstleister**
- Standardkonformität
 - In der Regel bedient OSS offene internationale Standards
- hohes Innovationspotenzial
 - Auch für neue Standards und Technologien gibt es in der Regel OSS
 - Referenzimplementierungen in der Regel OS
- Hohe Sicherheit durch Transparenz
 - Sicherheitslücken und Backdoors werden schneller entdeckt bzw. gar nicht erst eingebaut
- Lizenzkostenfrei
 - Nutzung an sich ist kostenlos

Open Source im Business-Kontext

*Offener Quellcode schafft maximale Transparenz und bietet höchste Flexibilität durch **Anpassungs- und Gestaltungsmöglichkeiten**. Dadurch bilden sich auch **Kooperationsräume**, durch die wertvolles Wissen mit enormem Innovationspotenzial entsteht.*

Diese Eigenschaften machen Open Source zu einer unverzichtbaren Basis nachhaltiger Wertschöpfung – nicht nur im Bereich Software.

*Die Vernetzung verschiedener Anwendungen, Cloud Computing, IoT und die Anbindung der Zukunft an das Heute, also ein Miteinander von etablierten und neuen Lösungen, all dies erfordert Interoperabilität, wie sie vorwiegend durch Open Source gewährleistet wird.
(Open Source Business Alliance [6])*



Freedom of Forking

Prinzipiell kann jeder jederzeit eine Kopie des Open-Source-Quelltextes („Abspaltung“, „Fork“, „Branch“) erstellen. Diese Technik wird auch innerhalb eines Projekts genutzt:

- Wenn ich ein neues Feature entwickeln möchte, erstelle ich mir eine Kopie („Branch“, „interner Fork“), in der ich das entwickle
- Wenn ich fertig bin, erstelle ich einen Merge-Request
- Wenn der Merge Request angenommen wird, kommt das neue Feature zurück in den Haupt-Quelltext

Diese Technik wird von allen Versionskontrollsystemen (z. B. CVS, SVN, Git) unterstützt

Freedom of Forking

Motivationen für einen echten (also nicht internen) Fork:

- Maintainer ist nicht gewillt, mein Feature zu übernehmen ()
- Mutterprojekt wird nicht mehr gepflegt ()
 - Projekt wurde eingestellt
 - Maintainer kümmert sich nicht mehr wirklich um das Projekt
- Maintainer wechselt die Firma, das Copyright hat die alte Firma ()
- Die Firma, die das Copyright besitzt, wird aufgekauft von einer Firma, die das Produkt Closed Source stellen möchte ()
- Es gibt grundsätzliche Uneinigkeiten in der Entwicklercommunity bez. Roadmaps, Bibliotheken, „philosophische“ Fragen ()

() = einverständlich () = kompetitiv

Freedom of Forking

Die Gründe für Forks [7] sind meistens einverständlich:

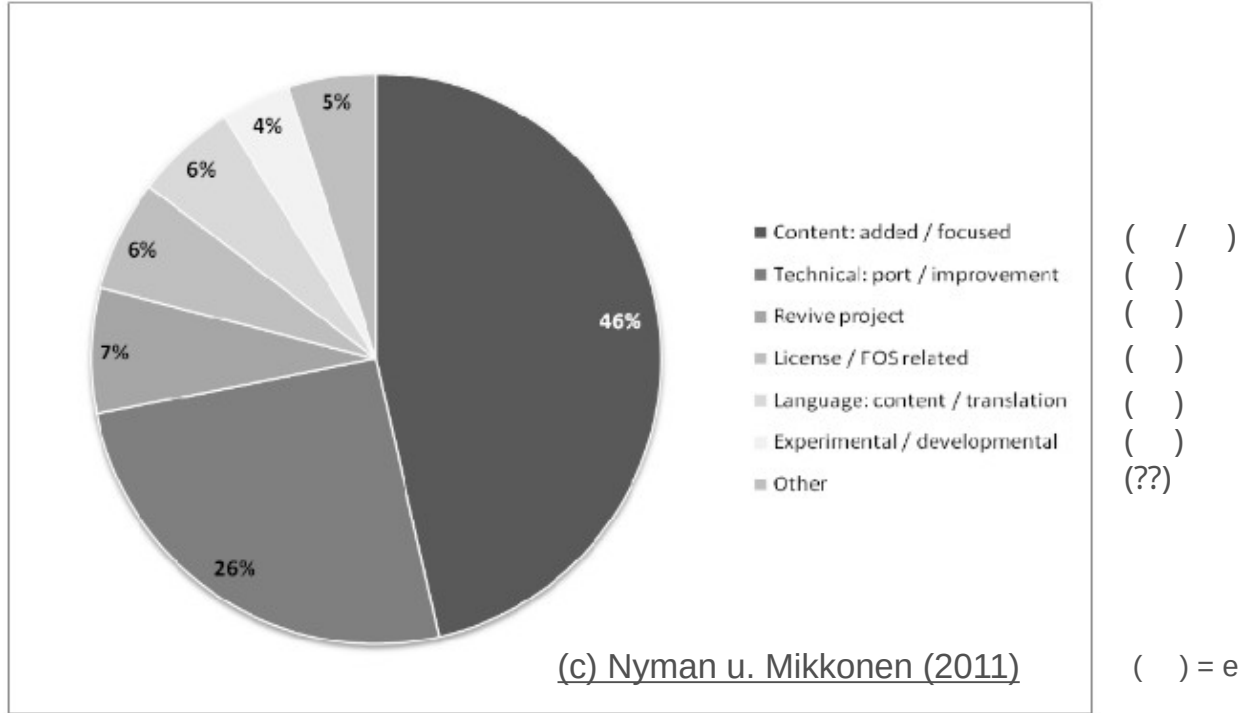


Fig. 1. Fork motivations in SourceForge projects

(/) = einverständlich () = kompetitiv

Freedom of Forking: Issues

Gründe, die gegen einen echten Fork sprechen:

- Duplizierung des Aufwands
 - Neue Features in beiden Kopien einpflegen
 - Überhaupt der Pflegeaufwand:
 - Sicherheitspatches
 - Neue Bibliotheksversionen, neue Betriebssystemversionen
 - Roadmap / Releases
 - Support (Mailingliste etc.)
 - Community management
 - Contributors werden aufgeteilt
 - Die einen bleiben im Mutterprojekt, die anderen arbeiten nur noch für den Fork
 - Die wenigsten werden in beiden Projekten arbeiten
 - User werden aufgeteilt
 - Die einen bleiben, die anderen wechseln

Freedom of Forking: Beispiele

- Beispiele für erfolgreiche Forks:
 - OpenOffice → LibreOffice
 - MySQL → MariaDB
 - Owncloud → Nextcloud
→ OpenCloud
 - ElasticSearch → OpenSearch
 - LinOTP → privacyIDEA
 - **privacyIDEA → eduMFA**



privacyIDEA

- Open-Source-Software für Multifaktor-Authentifizierung (MFA)
- Hauptentwickler von LinOTP war nicht mehr einverstanden mit der Firmenpolitik und hat sich mit einem Fork (privacyIDEA) selbstständig gemacht (Firma Netknights)
- Beide Produkte (LinOTP und privacyIDEA) sind auf dem Markt
- privacyIDEA hat sich wesentlich schneller weiterentwickelt
- Mit der privacyIDEA Enterprise Edition zielt die Software eher auf Kunden in der Wirtschaft ab

privacyIDEA

privacyIDEA besteht u. a. aus folgenden Softwareprodukten:

- privacyIDEA API
- Library für verschiedene Token-Typen
- Frontends für Administration und Self-Service
- LDAP Proxy
- PAM-Modul
- RADIUS-Integration
- Plugins für verschiedene IdPs (Shibboleth, Keycloak etc.)
- Windows Credential Provider für MFA beim Windows-Login

Hochschulen und MFA

- Wegen steigender Angriffszahlen, etwa durch Ransomware, sehen sich die Hochschulen in der Pflicht, flächendeckend (also auch für Studierende) Multifaktor-Authentifizierung (MFA) einzuführen
- Richtig eingeführt erhöht MFA die Sicherheit sensibler IT-Umgebungen beträchtlich
- Hochschulen sind Open-Source-affin
- Hochschulen haben eigene Anforderungen z. B.:
 - bezüglich Enrollements (Studierende vs. Mitarbeitende)
 - Statistikerhebungen
- Mehrere wissenschaftliche Einrichtungen in Deutschland haben sich als Usergroup zusammengetan

Motivation für den Fork eduMFA



- Eigener Integrationsszenarien mit Fokussierung der Funktionen auf Hochschulen und andere wissenschaftlichen Einrichtungen
- Schaffung einer gemeinsamen Plattform für IT-Sicherheit
- Eigene breite Entwicklerbasis, langfristiges Commitment
- Aufbau eines zentralen Supports im Wissenschaftsnetz
- Möglichkeit, frei eigene Features zu entwickeln
- Enger Austausch mit Shibboleth-Konsortium (Shibboleth wird in Hochschulen sehr häufig als Identity Provider eingesetzt)
- Es wurde bereits ein eigenes Shibboleth-Plugin entwickelt für die Integration von MFA: fudiscr [8]

eduMFA Projektpartner



Steffen Hofmann, Erwin Kupris

eduMFA: Aktueller Stand und geplante Entwicklungen

4

Status eduMFA



- Projektseite: <https://edumfa.io>
- Sourcecode auch auf Github: <https://github.com/eduMFA/eduMFA>
- Fork von privacyIDEA 3.9.2
 - API und Frontends durch Hochschule München und Freie Universität Berlin
 - LDAP Proxy durch DAASI International
 - Weitere Forks in Planung
- Erste WebAuthn-Erweiterung: **Unterstützung von Passkey (userless authentication)**
- Verbesserungen
 - in Testing, Sicherheit (ab eduMFA 2.9.2)
 - und Performance in großen Deployments (ab eduMFA 2.10.0)
- kontinuierliches Updaten der Bibliotheken
- Bugfixes
- Erweiterung SMS-Token mit Benachrichtigung per User
- eduMFA Authenticator App von der GWDG und der FU Berlin

eduMFA Support



- Sehr aktive Entwicklercommunity
 - Aktive Mailinglisten
 - transparente Planung weiterer neuer Features
- Kommerzieller Support durch DAASI International:
 - Consulting, Aufbauprojekte
 - 2nd-Level Helpdesk
 - eduMFA as a Service (OnPremise oder Full-Cloud)
- Weitere Firmen bieten Support für eduMFA an (Ssystems, Berlin; GWDG, Göttingen; Helsinki Systems, Stuttgart)
- In Arbeit: Aufbau eines Userkonsortiums (eduMFA-Verein) über das kommerzieller 3rd-Level-Support angeboten werden soll

eduMFA: Aktives Projekt auf github.com



README.md



Pinned

 **eduMFA** Public
Up-to-date multifactor authentication for academic institutions.
● Python ☆ 67 🍴 28

Repositories

Find a repository... Type ▾ Language ▾ Sort ▾

eduMFA Public
Up-to-date multifactor authentication for academic institutions.
● Python ☆ 67 🍴 28 🕒 63 (1 issue needs help) 📄 37 Updated 1 hour ago



authenticator-next Public
The new eduMFA Authenticator rewritten in React Native
● TypeScript ☆ 0 🍴 0 🕒 4 📄 6 Updated 2 days ago



Web Public
edumfa.io website
● TypeScript ☆ 2 🍴 2 🕒 2 📄 1 Updated 3 days ago



authenticator Public
Authenticator App for eduMFA Authentication Server
● Dart ☆ 5 🍴 2 🕒 6 📄 6 Updated last week



reupic



Top languages

● TypeScript ● Python ● Dart

Vgl. <https://github.com/eduMFA>
(Stand 03.07.26, 18:00)

eduMFA: Copyleft-Lizenz AGPL



eduMFA / LICENSE

 eduMFA/eduMFA is licensed under the
GNU Affero General Public License v3.0

Permissions of this strongest copyleft license are conditioned on making available complete source code of licensed works and modifications, which include larger works using a licensed work, under the same license. Copyright and license notices must be preserved. Contributors provide an express grant of patent rights. When a modified version is used to provide a service over a network, the complete source code of the modified version must be made available.

Permissions	Limitations	Conditions
✓ Commercial use	✗ Liability	① License and copyright notice
✓ Modification	✗ Warranty	① State changes
✓ Distribution		① Disclose source
✓ Patent use		① Network use is distribution
✓ Private use		① Same license

This is not legal advice. [Learn more about repository licenses](#)

 **Cornelius Kölbel** init: code cleanup 739b2c1 · 11 years ago

Code Blame 620 lines (512 loc) · 31.6 KB

Raw Copy Download

```
1          GNU AFFERO GENERAL PUBLIC LICENSE
2          Version 3, 19 November 2007
3
4  Copyright (C) 2007 Free Software Foundation, Inc. <http://fsf.org/>
5  Everyone is permitted to copy and distribute verbatim copies
6  of this license document, but changing it is not allowed.
7
8          Preamble
9
10 The GNU Affero General Public License is a free, copyleft license for
11 software and other kinds of works, specifically designed to ensure
12 cooperation with the community in the case of network server software.
13
14 The licenses for most software and other practical works are designed
15 to take away your freedom to share and change the works. By contrast,
16 our General Public Licenses are intended to guarantee your freedom to
17 share and change all versions of a program--to make sure it remains free
18 software for all its users.
19
20 ...
```

Vgl. <https://github.com/eduMFA/eduMFA/blob/main/LICENSE>

Einführung eduMFA

eduMFA ist ein modularer Authentifizierungsserver für sichere Authentifizierung

- ergänzt bestehende User-Accounts um Zwei-Faktor-Authentifizierung
- Integration in bestehende User-Datenbank (Beispiel: LDAP, aber auch File, Database etc.)
- große Anzahl an zweiten Faktoren/Tokentypen
- integriertes Administrationsportal
- Integrierter User-Self-Service
- Hohe Flexibilität und Konfigurierbarkeit
- Konzept von „Realms“ für ein Multi-Mandanten-System



Einführung eduMFA

eduMFA ist mit anderen Systemen integrierbar

- Der „Kern“ von eduMFA ist eine REST-API, über die alle Funktionen verwendet werden können, sodass es einfach in andere Systeme integrierbar ist:
 - Integration in Identity Provider für Web-SSO
 - Shibboleth (FU Berlin)
 - Satoria (DAASI Int.)
 - SimpleSAMLphp (GWDG)
 - Integration in RADIUS für non-Web
 - FreeRADIUS
 - Integration in didmos (DAASI Int.)
 - Integration in LDAP-Abfragen (DAASI Int.)
 - Integration in Windows-Login (Helsinki Systems)



Unterstützung von vielen Tokentypen als zweiter Faktor

- One Time Password (OTP) via Apps à la Google Authenticator
 - TOTP (Time-based)
 - HOTP (Hash-based)
- Push Token (per eduMFA App)
- OTP per E-Mail oder SMS
- WebAuthn / FIDO2 / **Passkeys** (user and passwordless)
- Yubikey, Nitrokey und andere Hardware-Token (diverse Protokolle/Typen)
- Indexed Secret (einfacher challenge: gib mir Zeichen X und Y des Passworts, der Map)
- TAN Liste

Passkeys Grundlage FIDO2

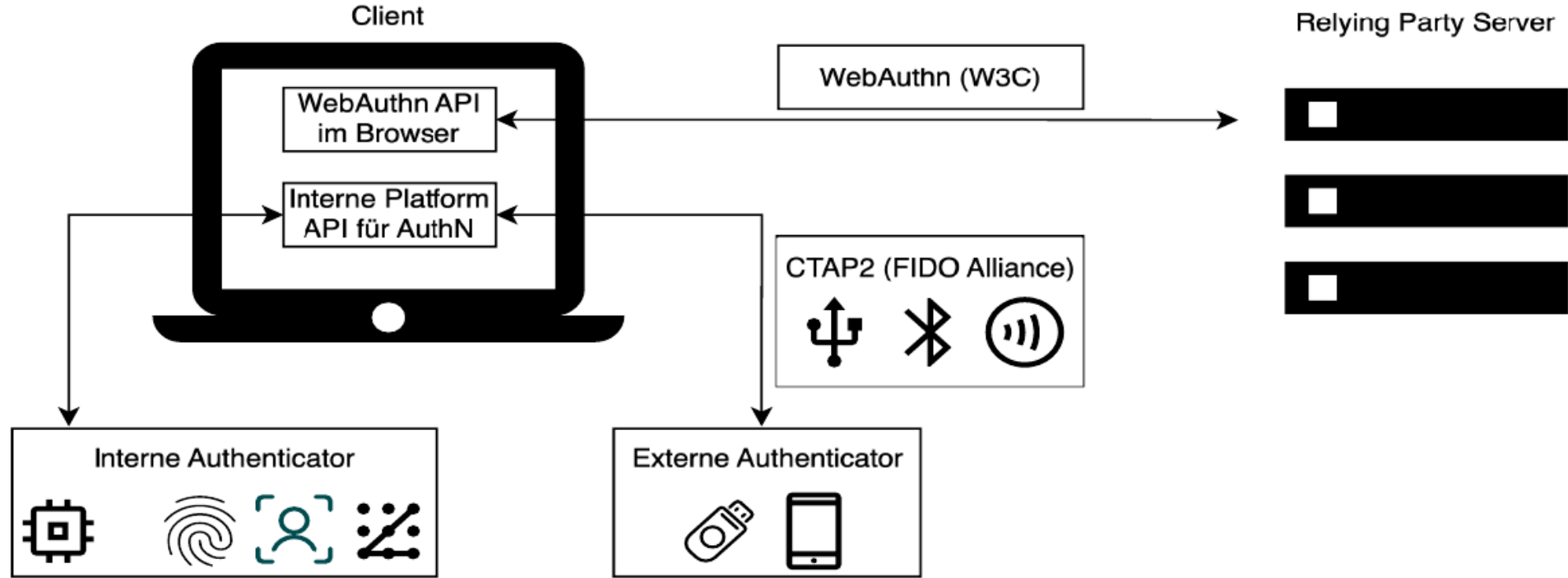


- FIDO2 ist ein internationaler Standard für MFA, der von der FIDO-Alliance und dem W3C gemeinsam entwickelt wurde
- Es beinhaltet verschiedene kryptografische Kommunikationsprotokolle zwischen Authenticator (A), Client (C) und Relying Party (RP):
 - CTAP2 (Client To Authenticator Protocol v2) von FIDO-Alliance:
 - Nachfolger von CTAP1/U2F (Universal 2nd Factor)
 - Regelt Kommunikation zwischen einem Sicherheitsgerät (A) und einem Endgerät (C)
 - WebAuthn von W3C
 - Regelt die Kommunikation zwischen Endgerät (C) und Anwendung (RP)

Passkeys Grundlage FIDO2



Grundlagen: FIDO2



Vgl. https://www.dfn-cert.de/documents/173/2_Unlocking_the_Future_of_eduMFA.pdf

Passkeys Grundlage FIDO2



- Basiert auf asymmetrischer Kryptographie (X.509)
- Weil Challenge-Response-Verfahren ist es resistent gegen Phishing
- Es wird immer der User Consent abgefragt
- Eignet sich für Ein-, Zwei- oder Mehrfachauthentisierung
- Über „discoverable credentials“ (DC) ist es möglich, sich auch ohne Usernamen zu authentifizieren
- Passkeys ist eine Erweiterung der DC:
 - Die geheimen und in den Authentifikatoren abgelegten und damit nicht kopierbaren Primärschlüssel sind bei Passkeys nicht mehr an einen Authentifikator gebunden
 - Deshalb ist dieses Verfahren universeller einsetzbar

eduMFA Anpassungen für Passkeys



- Integration von Passkeys
- Generierung von Challenges ohne einen Nutzer zu kennen
- Neue Policys für Passkeys, Passwordless und Usernameless Login



- Shibboleth Login-Views unterstützen Passkeys und Conditional Mediation
- fudiscr unterstützt nun Passkeys und den Login ohne Nutzernamen

Vgl. ebenda

Administration, Self-Service & REST-API

- sehr umfangreiche dokumentierte REST-API für alle Funktionen, wie Token-Management, Validierung und Konfigurationsänderungen
- eduMFA bietet ein Frontend-Interface für Administration und Self-Service, welches (fast) vollständig die API bedient
- Damit lassen sich solche Funktionen auch in andere, bestehende Tools für Benutzermanagement integrieren (Beispiel: didmos LUI)

Administration, Self-Service & REST-API

- Durch den API-Ansatz lassen sich Validierung und Management in beliebige andere Tools integrieren
 - Auflisten von Tokens (GET /token/)
 - Auslösen von „Triggerchallenge“ (POST /validate/triggerchallenge)
 - Validierung von Tokens (POST /validate/check)
 - Management von Tokens: Integration in bestehende Self-Service- und Admin-Tools
- Die folgenden Enrollmentstrategien gelten sowohl für eduMFA-Frontends als auch für selbst entwickelte Frontends

Integration in SSO über Shibboleth IdP oder didmos

- Empfehlung: Integration von möglichst vielen Web-basierten Anwendungen über SSO
- Verschiedene Integrationsszenarien möglich
 - Auf Nutzerbasis: Für alle Nutzer, für manche Nutzer, optional
 - Auf SP-Ebene: Für alle SPs, für manche SPs, Step-Up-Authentication
- eduMFA als Lösung für den zweiten Faktor. Der erste Faktor wurde ja vom IdP bereits über die reguläre Authentifizierung überprüft

eduMFA – Integration in SSO



- Empfehlung: Zentrale Plattform zur Authentifizierung von Web-Anwendungen und darüber hinaus, zum Beispiel Shibboleth IdP
 - Unterstützung vom SimpleSAMLphp und Keycloak
 - Integration in Shibboleth IdP und Satsa
- Nicht alle Tokens funktionieren mit allen Integrationen, können aber nachgerüstet werden
 - Immer gehen OTP-artige Tokens inklusive Code per E-Mail/SMS
- Beispiel: prüfe auf Vorhandensein von Tokens per API, gegebenenfalls Auslösen von Challenge-Response, validiere Token
 - aber auch: Direktabfrage eines Tokenwerts für einen User
- IdP nutzt eduMFA zur Validierung von Tokens, darüber hinaus ist die Logik jedoch im IdP umgesetzt (Reihenfolge der Tokens, etc.)

Weitere Integrationsszenarien

- Per REST-API (analog zu SSO Plugin)
- RADIUS per FreeRADIUS
- PAM-Integration (eduMFA liefert das eigene PAM-Modul pam_python)
- LDAP-Authentifizierung per LDAP-Proxy (z.B. für OpenLDAP)
- Windows via Credential Provider

eduMFA – Integration in Shibboleth



Our Identity Provider

(replace this placeholder with your organizational logo / label)

Username

Password

☐ Don't Remember Login

☐ Clear prior granting of permission for release of your information to this service.

Login

› Forgot your password?

› Need Help?

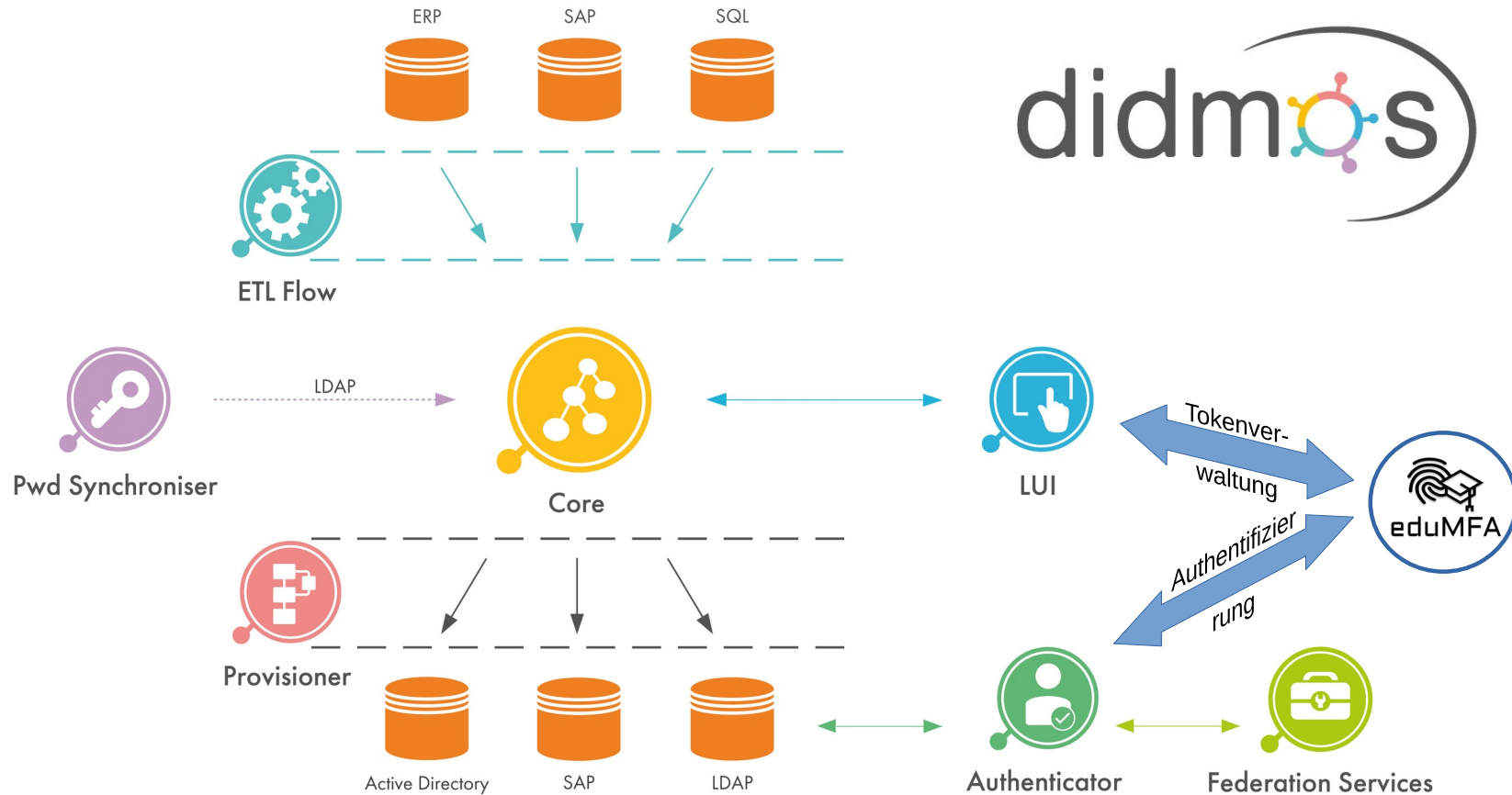
Token-based Login

Token code (test1)

Login



Integration in IAM-System didmos



- Enrollment von Tokens kann automatisiert, administrativ oder im User-Selfservice erfolgen, je nach Konfiguration über Policys
 - automatisiert: über externe Workflows und API-Zugriff oder eduMFA-Trigger- oder Tasks
 - administrativ: über Admin-Interface oder API-Zugriff
 - Selfservice: Self-Enrollment (QR-Code für TOTP oder Eingabe von Seeds)
- Welche Prozesse umgesetzt werden ist eine Einzelfallentscheidung, wobei Organisations-Richtlinien beachtet werden müssen
- Beispiel: Für konsequente Sicherheit muss Enrollment unabhängig vom ersten Faktor (Passwort) sein und damit scheidet in der Regel aus:
 - Nur über Selfservice
 - Nur über Übermittlung eines Codes per E-Mail

Administrativ

Ausrollen von Tokens
(z. B. FIDO2 oder
Yubikey) und
Zuweisung an User per
Administrationsinter-
face oder API

Self-Service

User können sich
(initial ohne MFA)
anmelden und selbst
ein Token (z. B. TOTP)
ausrollen

„Hybrid“

Initiales Token (TAN,
Indexed Secret)
administrativ
ausrollen, an User
übermitteln, die dann
im Self-Service
beliebige Tokens
selbst ausrollen

Administrativ

**Ausrollen von Tokens
(z. B. FIDO2 oder
Yubikey) und
Zuweisung an User per
Administrationsinter-
face oder API**

- Sinnvoll insbesondere für eine begrenzte User Anzahl (z. B. „Yubikeys für alle Admins“)
- Ggf. erweiterbar auf größeren Userkreis mit entsprechenden Kosten („Verschicken von Yubikey nach Immatrikulation“)
- Sicherheit des Transports der Tokens muss gewährleistet sein
- Integration in Login-Prozess üblicherweise: MFA verpflichtend für:
 - bestimmte Usergruppen
 - Bestimmte Anwendungen
- Support-Aufwand muss beachtet werden
 - bei begrenzter User Anzahl ggf. vernachlässigbar
 - Sonst Backup-Lösung administrativ ausrollen (TAN-Liste oder Indexed Secret)

Self-Service

**User können sich
(initial ohne MFA)
anmelden und selbst
ein Token (z. B. TOTP)
ausrollen**

- Offensichtliche Sicherheitsproblematik beim initialen Enrollment und damit mglw. Konflikt bei organisationsseitige Richtlinien
- Eher als optionales Angebot an User zu verstehen
- Kombiniert mit administrativ wieder sinnvoll (s.u.)
- Support-Aufwand muss beachtet werden
 - Policy zum Enrollment von mehreren Tokens
 - Recovery-Codes direkt beim Ausrollen mit erzeugen

„Hybrid“

Initiales Token (TAN, Indexed Secret) administrativ ausrollen, an User übermitteln, die dann im Self-Service beliebige Tokens selbst ausrollen

- Kostengünstiges Initialtoken (TAN-Liste oder Indexed Secret per Brief), welches administrativ und automatisiert in eduMFA erzeugt werden kann
- User kann zu keinem Zeitpunkt ohne MFA agieren
- Enrollment von dauerhaftem Token dann per Self-Service, idealerweise auch kostengünstig (z. B. TOTP/HOTP oder Passkeys)
- Sicherheit des Transports der Initialtokens sollte gewährleistet sein (also eher nicht Versand per E-Mail)
- Support-Aufwand muss beachtet werden
 - Policy zum Enrollment von mehreren Tokens
 - Backup-Lösung administrativ ausrollen (TAN-Liste oder Indexed Secret)

Automatisierte Ereignisse und Aufgaben

- **Event-Handler:** Zugriff während allen möglichen Funktionen (API-Calls) vor (Pre) oder nach (Post) der Ausführung der aufgerufenen Funktion
 - Mögliche Anwendungen vielfältig, z. B.
 - Automatisches Token-Enrollment
 - Onboarding-Aktionen bei neuen Usern
 - Clean-Up-Prozesse
 - Eigenes Logging
- **Regelmäßige Aufgaben** im „Cronjob-Stil“
 - Z.B.: Sammeln von Statistiken über aktuelle Token in eduMFA

eduMFA – Weitere Funktionen



- Audit-Log für detaillierte Protokollierung von Zugriffen
 - Auch im Self-Service möglich (DSGVO-relevant)
- Hinweise zum Betrieb
 - eduMFA hält (fast) alle Daten in einer SQL-Datenbank
 - Der API-Server an sich ist stateless
 - Hochverfügbarkeit durch Redundanz damit einfach möglich: Datenbank-Cluster-Setup und beliebig viele API-Server-Nodes
- Fokus beim Authentifizierungsbackend bisher auf LDAP-Userstore, aber auch SQL, SCIM, HTTP und Flatfile möglich

eduMFA – Interfaces und API



 eduMFA

Tokens

Users

Machines

Config

Audit

Components

Refresh

admin1 @admins (admin)

All tokens

Enroll Token

Import Tokens

List Challenges

Token Applications

Get Serial

Help about Token

total tokens: 2

serial● ▼	type● ▼	active●	description● ▼	failcounter●	rollout state● ▼	user	realm	To
TOTP00009E9E	totp	active		0	enrolled	user1	users	us
WAN0000EF7D	webauthn	active	Synced Passkey (WebAuthn Multi-Device Credential)	0		user2	users	us

Enroll a new token

The token was successfully enrolled with serial number [TOTP0001D01B](#).



Click [here](#) or scan the QR Code, if you want to add the Token to your smartphone authenticator app.

The QR Code contains the secret key of your token. You need to protect it. **If you are in doubt, that someone else saw it, please regenerate the QR Code, when no one else is watching.**

Regenerate QR Code

The token was enrolled, but you still need to verify it before you can use it!

Please enter a valid OTP value of the new token.

Verify Token

aktuell in Entwicklung



- Edumfa-credential-provider durch Helsinki Systems
- Helm Chart zum einfachen Deployment in Kubernetes-Clustern
- Reporting im Dashboard:
 - Wie viele meiner User haben einen Token?
 - ... einer bestimmten Art?
 - Visualisierung von gesammelten Statistiken (erfordert Konfiguration von „Regelmäßigen Aufgaben“)
- eduMFA Verein
 - Der Satzungsvorschlag wird gegenwärtig von den Rechtsabteilungen evaluiert.
 - Gründung noch in diesem Jahr sehr wahrscheinlich

Wer nutzt eduMFA bereits?



Vgl. <https://edumfa.io>



Fazit

- Mit dem Fork eduMFA hat sich eine spezielle Nutzergruppe, die Hochschulcommunity, digital souverän gemacht:
 - kann frei neue Roadmap definieren, die sich an die speziellen Anforderungen der Gruppe richtet
 - Sie teilen sich Entwicklerressourcen
 - geben sich gegenseitig Support
- Zusätzlich steht kommerzieller Support durch DAASI International mit definierten SLAs zur Verfügung einschließlich eduMFaaS
- Über APIs lässt sich eduMFA leicht in andere Anwendungen integrieren
- Als Open-Source-Produkt kann es natürlich auch von beliebigen anderen Nutzergruppen verwendet werden

Fazit

Was für Hochschulverbünde gilt, gilt gleichermaßen für viele weitere Interessengemeinschaften, insbesondere im behördlichen Bereich:

- Aufgrund der Gesetzgebung besteht hier ein erhöhter Digitalisierungsdruck,
- weshalb eine Open-Source-Lösung, die digitale Souveränität garantiert, beste Voraussetzungen bietet



Vielen Dank!

Email: info@daasi.de

Web: www.daasi.de

Büro: Europaplatz 3,
72072 Tübingen



Kommt zur International
Conference on LDAP
Tübingen, 6.-8. Oktober!

- [1] <https://www.uni-marburg.de/de/hrz/ueber-uns/profil/geschichte/1963-1983-die-grossrechner-aera>
- [2] https://en.wikipedia.org/wiki/History_of_free_and_open-source_software#Free_software_before_the_1980s
- [3] https://www.share.org/Portals/0/Docs/SHARE_1571014_Timeline.pdf
- [4] https://de.wikipedia.org/wiki/Open_Source
- [5] <https://opensource.org/osd/>
- [6] <https://osb-alliance.de/ueber-uns/leitlinien-der-osb-alliance-2022>
- [7] Nyman u. Mikkonen (2011); To Fork or Not to Fork: Fork Motivations in SourceForge Projects; https://link.springer.com/content/pdf/10.1007/978-3-642-24418-6_18.pdf?pdf=inline%20link
- [8] <https://doku.tid.dfn.de/de:shibidp:plugin-fudiscr>
- [9] Technische Richtlinie TR-03107-1 Elektronische Identitäten und Vertrauensdienste im E-Government, Teil 1: Vertrauensniveaus und Mechanismen
<https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.pdf>



<https://ldapcon.org>

